



CodeRabbit

QA BUG HUNTER REPORT

NOTJUST Watr

E-Commerce Platform · Full-Stack QA Analysis

16

CRITICAL

27

HIGH

25

MEDIUM

12

LOW

80 ISSUES IDENTIFIED



Analysis Summary

BY SEVERITY		BY CATEGORY	
Critical	16	Security	16
High	27	State	16
Medium	25	Logic	16
Low	12	UX	11
		API	5
		A11y	5
		Form	4
		Navigation	3
		Data	2
		Render	2

TOP AFFECTED COMPONENTS	
AdminPanel	21
ProductDetailPage	14
Orders API	5
CheckoutView	5
ProductLearningModule	4
API Utils	3
Auth API	3
AuthRegister	3

KEY FINDINGS	
Critical Security Vulnerabilities: Unsalted SHA-256 password hashing, forgeable session tokens, client-controlled pricing, and IDOR vulnerabilities expose the platform to complete authentication bypass and financial loss.	
State Management Issues: Race conditions, infinite retry loops, and stale closures in product detail and admin panels can cause wrong data display, API DDOS, and blank screens.	
Logic Errors: Tax calculated on pre-discount subtotal overcharges customers. Phone numbers sent un-normalized cause login failures. Quiz reorder crosses video boundaries.	
UX Defects: Double-submit on checkout, missing loading states, inaccessible elements, and layout shifts degrade user experience across all flows.	

• Critical Severity

16 issues

ADM-1 Stale Closure / Race Condition in Data Loading

CRITICAL **STATE** **ADMINPANEL** Data loading useEffect

DESC: Async load() inside useEffect has no cleanup/abort mechanism. Sequential for loop fetching quiz questions makes this especially slow and race-prone.

IMPACT: Stale data overwrites fresh data if user changes during load.

FIX:

```
Add AbortController and let cancelled = false flag; guard all setState calls.
```

ADM-2 refreshData() Doesn't Refresh All State

CRITICAL **DATA** **ADMINPANEL** refreshData()

DESC: refreshData re-fetches stats, users, campaigns, products, orders, subscriptions but SKIPS questions, productVideoCounts, productQuizCounts, and scans.

IMPACT: After creating/deleting a product, quiz counts and scan data are outdated.

FIX:

```
Extract a shared loadAllData() function used by both initial load and refresh.
```

ADM-3 Product Edit Doesn't Populate slug Field

CRITICAL **DATA** **ADMINPANEL** Product edit onClick

DESC: When clicking Edit on a product, setNewProduct is called with all fields EXCEPT slug. On save, auto-generate logic creates a new slug - potentially different from the original.

IMPACT: Editing any product and saving OVERWRITES the products URL slug, breaking existing QR codes, bookmarks, and SEO.

FIX:

```
Add slug: product.slug || "" to the setNewProduct call.
```

ADM-4 AdminPanel Calls navigateTo During Render

CRITICAL **STATE** **ADMINPANEL** AdminPanel export

DESC: if (!user?.is_admin) { navigateTo(landing); return null } performs side effect during render. Violates React's rules.

IMPACT: Potential infinite render loop; React strict mode will double-invoke it.

FIX:

```
Move the navigation into a useEffect.
```

ADM-5 XSS via window.open + document.write with Product Name

CRITICAL **SECURITY** **ADMINPANEL** Product QR button onClick

DESC: w.document.write(...) interpolates product.name and qrUrl directly into HTML. If product name contains script tags, it executes in new window context.

IMPACT: Stored XSS - malicious admin can execute arbitrary JavaScript.

FIX:

```
Use textContent / DOM APIs instead of document.write, or sanitize with DOMPurify.
```

AUTH-1 Phone Number Sent to API Un-normalized

CRITICAL **LOGIC** **AUTHWHATSAPPOTPLOGIN** handleSendOtp / handleLogin

DESC: Phone number is validated and normalized to localDigits but API is called with trimmedPhone (raw input). User enters +919876543210, API receives +919876543210 instead of 9876543210.

IMPACT: OTP may be sent to the wrong number format, or API may reject. Login fails for users entering international format.

FIX:

```
Replace phone: trimmedPhone with phone: localDigits in handleSendOtp and handleLogin.
```

AUTH-2 Phone Number Sent to API Un-normalized in Register

CRITICAL LOGIC AUTHREGISTER handleSendOtp

DESC: Same bug as AUTH-1. When registering with phone, raw trimmed input is sent instead of normalized number.

IMPACT: Registration OTP may fail for users entering phone with country code or leading zero.

FIX:

```
Use phone: formatPhone(trimmed) when sending the WhatsApp OTP.
```

CHECKOUT-1 Tax Calculated on Pre-Discount Subtotal (Overcharges Customer)

CRITICAL LOGIC CHECKOUTVIEW Price calculation

DESC: taxAmount = Math.round(subtotal * 0.18) computes GST on full undiscounted subtotal, then discountAmount is subtracted after tax. Per Indian GST rules, tax should apply to discounted price.

IMPACT: Customer is overcharged. Example: Item ₹1000 with 20% discount: current tax=₹180, correct tax=₹144. Overcharge of ₹36.

FIX:

```
const taxableAmount = subtotal - discountAmount; const taxAmount = Math.round(taxableAmount * 0.18);
```

CHECKOUT-2 Double-Submit on Rapid Button Clicks (Place Order)

CRITICAL STATE CHECKOUTVIEW handlePlaceOrder

DESC: placing state is read from render closure. If user clicks Place Order twice rapidly before React re-renders, both clicks proceed to create duplicate orders.

IMPACT: Duplicate orders created, customer double-charged for COD, cart cleared incorrectly.

FIX:

```
Add a placingRef = useRef(false) guard at the top of handlePlaceOrder.
```

PDP-1 Race Condition: No AbortController on Product Fetch

CRITICAL STATE PRODUCTDETAILPAGE Product fetch useEffect

DESC: Product fetch effect has no AbortController or cancelled flag. If selectedProductId changes rapidly, stale fetch can overwrite current product data.

IMPACT: User navigates from Product A to Product B. If fetch A resolves after fetch B, page shows wrong product data.

FIX:

```
Add let cancelled = false flag with cleanup, same pattern as progress fetch.
```

PDP-2 Infinite Retry Loop on Fetch Failure

CRITICAL STATE PRODUCTDETAILPAGE .catch block of product fetch

DESC: When product fetch fails, setFetchedId(selectedProductId) is never called. On re-render, fetchedId still != selectedProductId, so effect fires again infinitely.

IMPACT: If API is down, component enters infinite fetch-fail-render loop, potentially DDOSing the API and freezing the browser.

FIX:

```
Call setFetchedId(selectedProductId) inside the .catch() block.
```

SEC-1 Unsalted SHA-256 Password Hashing

CRITICAL SECURITY API UTILS hashPassword()

DESC: Passwords are hashed with plain SHA-256 with zero salt. SHA-256 is a fast cryptographic hash, not a password hashing function. Identical passwords produce identical hashes, making rainbow table attacks trivial.

IMPACT: Full database compromise reveals all user passwords in minutes. No per-user salt means one cracked password cracks all identical passwords instantly.

FIX:

```
Replace with bcrypt.hash(password, 12) / bcrypt.compare(password, hash). Bcrypt is slow (key stretching) and includes automatic per-hash salt.
```

SEC-2 Forgeable Session Tokens

CRITICAL **SECURITY** **AUTH API** register/route.ts:92, login/route.ts:60

DESC: Session token is Buffer.from("userId:timestamp").toString("base64"). Trivially reversible - decode from base64 to get the user ID. No cryptographic signature or HMAC.

IMPACT: Complete authentication bypass. Attacker can impersonate any user by constructing a token from their ID + any timestamp.

FIX:

```
Use jose or jsonwebtoken to sign JWTs with a server-side secret. Or generate crypto.randomBytes(32) tokens stored in a sessions table.
```

SEC-3 Client-Controlled Order Pricing (Price Manipulation)

CRITICAL **SECURITY** **ORDERS API** orders/route.ts:70-73

DESC: item.total_price, item.unit_price, and item.pack_discount are taken directly from client request body. Server never verifies against actual product prices in DB.

IMPACT: Customers can purchase products at arbitrary prices. Direct financial loss.

FIX:

```
Server must fetch real product prices from DB, calculate line totals server-side, and reject any client-provided pricing.
```

SEC-4 No Authorization on User-Specific Order Listing (IDOR)

CRITICAL **SECURITY** **ORDERS API** orders/route.ts:38-51

DESC: Any unauthenticated requester can fetch any users orders by passing ?user_id=victim_id. No session verification.

IMPACT: Any user can view all orders, shipping addresses, phone numbers, and payment details of any other user.

FIX:

```
Verify the session tokens user ID matches the requested user_id.
```

SEC-5 No Authorization on Order Cancellation

CRITICAL **SECURITY** **DATA SERVICE** orderService.cancel()

DESC: orderService.cancel() sends PATCH with { status: CANCELLED } and no admin or user ownership headers. Any user can cancel any order by ID.

IMPACT: Any authenticated user can cancel orders belonging to other users.

FIX:

```
Include user verification headers. Server must verify the session user owns the order or is an admin.
```

• High Severity

27 issues

ADM-11 Number Inputs Show Empty for Zero Values

HIGH **FORM** **ADMINPANEL** Product form

DESC: `value={newProduct.price || ""}` - when price is 0, `||` evaluates to `""`, showing empty input.

IMPACT: Admin cannot set price/mrp/stock to 0; input appears empty.

FIX:

```
Use nullish coalescing: value={newProduct.price ?? ""}.
```

ADM-12 Quiz Reorder Swaps Across Video Boundaries

HIGH **LOGIC** **ADMINPANEL** handleReorderQuiz

DESC: `handleReorderQuiz` finds quiz in full array and swaps adjacent item. But UI shows quizzes filtered by `video_id`. Swap may cross video boundaries.

IMPACT: Reordering quiz within one video accidentally swaps with quiz from different video.

FIX:

```
Filter learningQuizzes by same video_id before finding adjacent items.
```

ADM-13 x-admin-key: true Is Not Real Authentication

HIGH **SECURITY** **ADMINPANEL** handleEditUser, handleDeleteUser

DESC: Admin API calls use hardcoded header `x-admin-key: true`. Any user can spoof by adding this header to requests.

IMPACT: Any authenticated user could call admin APIs by adding this header.

FIX:

```
Remove client-side admin key; rely solely on server-side session verification.
```

ADM-6 `||` vs `??` for learningCompleted Fallback (7 locations)

HIGH **LOGIC** **ADMINPANEL** Dashboard stats

DESC: `stats.learningCompleted || stats.learningCompletions` uses `||` which treats 0 as falsy. Zero completions shows incorrect data.

IMPACT: Dashboard shows wrong completion counts when exactly 0 users completed learning.

FIX:

```
Replace || with ?? (nullish coalescing) operator.
```

ADM-7 Kanban Order Status Update Has No Error Handling

HIGH **API** **ADMINPANEL** Kanban card `onValueChange`

DESC: `await orderService.updateStatus()` has no `try/catch`. If API call fails, no error toast, no rollback.

IMPACT: Failed status updates silently fail with no feedback.

FIX:

```
Wrap in try/catch with toast.error() on failure.
```

ADM-8 Blank Page on Error (No Error State)

HIGH **RENDER** **ADMINPANEL** `if (!stats) return null`

DESC: After loading, if API failed and stats is null, component returns null - completely blank admin panel.

IMPACT: Admin sees blank white page with no indication of what went wrong.

FIX:

```
Add error state with retry button: if (!stats) return <ErrorState onRetry={refreshData} />.
```

ADM-9 Gender Select Has No Empty/Null Option

HIGH **FORM** **ADMINPANEL** Edit user dialog

DESC: When `editUserForm.gender` is `""`, `Select value=""` doesn't match any `SelectItem`. Radix Select in invalid state.

IMPACT: Select may show unexpected behavior; cannot unset gender once selected.

FIX:

```
Add SelectItem value="" for "Prefer not to say" or use undefined as uncontrolled default.
```

API-2 No Authentication on Order Creation

HIGH API ORDERS API POST handler

DESC: Any unauthenticated request can create an order for any user_id. No session or cookie verification.

IMPACT: Attackers can place fraudulent orders under any users account.

FIX:

```
Validate session token from cookie. Ensure session user ID matches body.user_id.
```

AUTH-3 Registration Doesnt Pass OTP Verification ID to Server

HIGH SECURITY AUTHREGISTER handleRegister

DESC: authService.register() called without passing otpId. Server has no proof that contact was verified before account creation.

IMPACT: Security gap - malicious user could register with unverified email/phone.

FIX:

```
Pass otp_id: otpId in the registration payload.
```

AUTH-4 "Keep me signed in" Checkbox Is Non-Functional

HIGH UX AUTHLOGIN/AUTHREGISTER Keep me signed in checkbox

DESC: keepSignedIn state toggled but never passed to authService.login() call. Checkbox has zero effect on session persistence.

IMPACT: Users believe theyre choosing session persistence but always get default behavior.

FIX:

```
Pass keepSignedIn to the login API, or remove the checkbox.
```

CHECKOUT-3 Total Amount Can Go Negative with Excessive Discount

HIGH LOGIC CHECKOUTVIEW Price calculation

DESC: totalAmount = subtotal + taxAmount - discountAmount has no floor guard.

IMPACT: Negative order total could be submitted to the server.

FIX:

```
const totalAmount = Math.max(0, subtotal + taxAmount - discountAmount)
```

LP-1 Badge Position Overlap (Locked + Discount Label)

HIGH UX LANDINGPAGE / PRODUCTPAGE Product card badges

DESC: Locked badge and discount_label badge both render at absolute top-4 left-4. When both conditions true, they stack directly on top of each other.

IMPACT: Jumbled overlapping text in top-left corner of product cards. Discount promotion hidden behind Locked badge.

FIX:

```
Offset badges conditionally or stack vertically.
```

PDP-3 State Leak: descExpanded Not Reset on Product Change

HIGH STATE PRODUCTDETAILPAGE descExpanded state

DESC: descExpanded stays true when navigating to a different product, so new products description shows fully expanded.

IMPACT: Product B description shown fully expanded with no View More option.

FIX:

```
useEffect(() => { setDescExpanded(false) }, [selectedProductId])
```

PDP-4 State Leak: quantity Not Reset on Product Change

HIGH STATE PRODUCTDETAILPAGE quantity state

DESC: quantity persists across product navigation. User sets qty=5 for Product A, navigates to Product B - cart add uses qty=5 for Product B.

IMPACT: User unknowingly adds wrong quantity to cart for a different product.

FIX:

```
useEffect(() => { setQuantity(1) }, [selectedProductId])
```

PDP-5 handleAddToCart Uses product Instead of displayProduct

HIGH LOGIC PRODUCTDETAILPAGE handleAddToCart

DESC: Handler guards on product (fully fetched data), but UI renders using displayProduct (cached). When product is null but displayProduct exists, Buy Now button does nothing silently.

IMPACT: User clicks Buy Now on completed product during brief window - nothing happens.

FIX:

```
Use displayProduct in the handler, or disable button until product is fully loaded.
```

PDP-6 Aggressive Cutoff for Barely-Long Text

HIGH UX PRODUCTDETAILPAGE About This Product truncation

DESC: isLong triggers at desc.length > 200, but midPoint is desc.length/2. For 201-char description, truncated view shows only ~100 characters - cutting away half the content.

IMPACT: Users see very little content before needing to click View More.

FIX:

```
Use fixed truncation target of ~180 chars instead of midpoint.
```

PDP-7 Truncation Only Searches Forward for Break Point

HIGH LOGIC PRODUCTDETAILPAGE About This Product truncation

DESC: Break-point search only looks forward from midpoint (80 chars ahead). If sentence end exists 20 chars BEFORE midpoint, better break point is missed.

IMPACT: Text gets cut mid-sentence when natural break exists just before search window.

FIX:

```
Search backward first, then forward from truncation target.
```

PLM-1 Infinite Loading Spinner When selectedProductId Is Null

HIGH STATE PRODUCTLEARNINGMODULE Data fetch useEffect

DESC: Data fetch returns early when !selectedProductId but never sets loading=false. User navigating to /learn with no product selected sees infinite spinner.

IMPACT: Users stuck on infinite loading screen with no escape.

FIX:

```
Add early return: if (!selectedProductId) { setLoading(false); return } or render empty state.
```

PLM-2 Stale videoProgress Closure in onLoadedMetadata

HIGH STATE PRODUCTLEARNINGMODULE onLoadedMetadata

DESC: Video onLoadedMetadata callback reads videoProgress from render closure. If component re-renders between setting progress and metadata event, callback uses stale value.

IMPACT: Video playback resumes at wrong position when returning to partially-watched video.

FIX:

```
Use a ref (videoProgressRef) synchronized with state, read from ref in onLoadedMetadata.
```

PLM-3 Race Condition in saveVideoProgress (Stale Progress Object)

HIGH STATE PRODUCTLEARNINGMODULE saveVideoProgress

DESC: saveVideoProgress reads progress from useCallback closure. Two rapid saves: second call uses pre-save progress and overwrites first saves data.

IMPACT: Quiz answers or video progress silently lost on rapid interaction.

FIX:

```
Use a ref to track latest progress, or implement queue/debounce for saves.
```

PLM-4 handleSeek Doesnt Clamp to 0-100

HIGH LOGIC PRODUCTLEARNINGMODULE handleSeek

DESC: pct = Math.round(((e.clientX - rect.left) / rect.width) * 100) never clamped to [0,100]. Edge clicks can produce negative or >100 values.

IMPACT: Video progress can show >100% or negative values, causing visual glitches and corrupting saved data.

FIX:

```
const pct = Math.max(0, Math.min(100, Math.round(...)))
```


PROFILE-1 Change Password Allows Empty Current Password

HIGH SECURITY PROFILEPAGE ChangePasswordButton

DESC: currentPassword field is optional. API called with currentPassword: currentPassword || "". Anyone with session can change password without knowing existing one.

IMPACT: If session is hijacked, attacker can set new password and lock out original user.

FIX:

```
Require OTP verification for password change, or require current password for password-holding accounts.
```

PROFILE-2 No AbortController for Data Fetches

HIGH STATE PROFILEPAGE Data fetch useEffect

DESC: fetchData async function doesnt use AbortController. If user navigates away while loading, promises update state on unmounted component.

IMPACT: React state update on unmounted component warnings; potential memory leaks.

FIX:

```
Add AbortController with cleanup in the useEffect return.
```

SEC-6 Timing-Vulnerable Password Comparison

HIGH SECURITY APIUTILS verifyPassword()

DESC: Uses === for hash comparison, vulnerable to timing attacks.

IMPACT: With enough timing measurements, attacker can recover the password hash offline.

FIX:

```
Use crypto.timingSafeEqual(Buffer.from(inputHash), Buffer.from(storedHash)).
```

SEC-7 user_id Cookie Accessible to JavaScript (XSS Exfiltration)

HIGH SECURITY AUTH API register/login cookie set

DESC: user_id cookie is set with httpOnly: false, readable by any JS. Combined with forgeable token, XSS can steal user ID and construct valid session token.

IMPACT: Any XSS vulnerability leads to immediate account takeover.

FIX:

```
Set httpOnly: true. Pass user_id through response body instead.
```

SEC-8 Unauthenticated Health Endpoint Leaks Database URL & Secrets

HIGH SECURITY HEALTH API health/route.ts

DESC: /api/health requires zero auth and returns masked DB URL (hostname/port still visible), Node version, platform, and whether secrets are set.

IMPACT: Attackers gain reconnaissance data for targeted attacks.

FIX:

```
Add auth to health endpoint. Strip database.url to just provider type.
```

SEC-9 x-admin-key Header Check Is Security Theater

HIGH SECURITY APIUTILS checkAdmin()

DESC: The x-admin-key header is checked only for existence (if (!adminKey)), not for a specific secret value. Any value - even "false" - passes.

IMPACT: Header check provides zero security. False sense of layered security.

FIX:

```
Validate against server-side secret: if (adminKey !== process.env.ADMIN_SECRET_KEY).
```

• Medium Severity

25 issues

ADM-15 No Loading State During Save

MEDIUM **STATE** **ADMINPANEL** `handleSaveVideo/handleSaveQuiz`

DESC: No saving boolean set during async save. Save button not disabled during API call.

IMPACT: User can double-click save, creating duplicate videos/quizzes.

FIX:

```
Add savingVideo/savingQuiz state; disable save buttons while saving.
```

ADM-17 Destructive Actions Use Browser confirm() Instead of Dialog

MEDIUM **UX** **ADMINPANEL** `Delete handlers`

DESC: `handleDeleteVideo`, `handleDeleteQuiz`, product delete use native `window.confirm()` while user delete uses proper Dialog.

IMPACT: Inconsistent delete experience; confirm dialogs may be suppressed by popup blockers.

FIX:

```
Replace with Dialog components like the user delete confirmation.
```

ADM-18 Revenue Trend Data Is Fabricated

MEDIUM **LOGIC** **ADMINPANEL** `revenueTrend computation`

DESC: Chart uses hardcoded multipliers (0.1, 0.12, 0.18, 0.22, 0.28, 0.32) applied to totalRevenue. Multipliers sum to 1.22 - chart shows 122% of actual revenue.

IMPACT: Admin sees misleading trend visualization that doesnt reflect reality.

FIX:

```
Fetch actual monthly revenue data from API, or clearly label as Projected/Estimated.
```

ADM-23 CANCELLED Orders Missing from Kanban

MEDIUM **LOGIC** **ADMINPANEL** `orderStatuses`

DESC: `orderStatuses = [PLACED, CONFIRMED, SHIPPED, DELIVERED]` excludes CANCELLED. Cancelled orders invisible in kanban view.

IMPACT: Admin cannot see cancelled orders in kanban view.

FIX:

```
C
```

ADM-26 Campaign Has No Delete Action

MEDIUM **LOGIC** **ADMINPANEL** `CampaignManagerInner`

DESC: Campaigns can be created and toggled but never deleted. No delete button exists.

IMPACT: Mistakenly created campaigns cannot be removed; only archived.

FIX:

```
Add delete button with confirmation dialog.
```

ADM-27 Subscriptions Tab Is Read-Only With No Actions

MEDIUM **UX** **ADMINPANEL** `Subscriptions tab`

DESC: No action buttons - no way to pause, cancel, or modify subscriptions.

IMPACT: Admin cannot manage subscriptions; can only view them.

FIX:

```
Add status change and detail view actions.
```

ADM-36 No Pagination on Any Table

MEDIUM **UX** **ADMINPANEL** `All tables`

DESC: All tables render full dataset with no pagination or virtual scrolling.

IMPACT: Performance degradation and poor UX with large datasets.

FIX:

```
Add pagination (20 items per page) or virtualized scrolling.
```

API-3 Order Creation Missing Item Validation

MEDIUM API ORDERS API POST handler

DESC: Checks items but doesn't validate individual item structure. Missing product_id, product_name will cause Prisma runtime error.

IMPACT: Malformed orders with null product references corrupt data integrity.

FIX:

```
Validate each item has product_id, product_name, unit_price, total_price.
```

API-4 No Stock Validation or Decrement on Order Placement

MEDIUM API ORDERS API POST handler

DESC: Orders created without checking stock or decrementing quantities.

IMPACT: Customers can order out-of-stock products. Inventory never updated.

FIX:

```
Add transaction: check stock, decrement, then create order using db.$transaction().
```

AUTH-6 Auto-redirect useEffect Missing Dependencies

MEDIUM STATE AUTHREGISTER/AUTHWHATSAPPOTPLOGIN Auto-redirect useEffect

DESC: useEffect for auto-redirect has [step] as only dependency but uses redirectAfterLogin, setRedirectAfterLogin, navigateTo.

IMPACT: Stale redirect target - user may be redirected to outdated view.

FIX:

```
Add all used values to dependency array.
```

CART-2 No Maximum Quantity / Stock Validation

MEDIUM LOGIC CARTITEMCARD Quantity controls

DESC: Plus button has no upper limit. Users can add unlimited quantity with no client-side stock check.

IMPACT: Users may add more items than available stock; order may fail server-side with poor error messaging.

FIX:

```
Add maxQuantity prop from product stock data and disable Plus button when reached.
```

CHECKOUT-4 Shipping Form Not Pre-Filled from User Profile

MEDIUM UX CHECKOUTVIEW Form initialization

DESC: shippingAddress, shippingCity, shippingPincode initialized as empty strings even though user profile may have address data.

IMPACT: Returning users must re-type their full address every time.

FIX:

```
Pre-fill from user.address, user.city, user.pincode if available.
```

FORM-1 No <form> Elements; Enter Key Doesn't Submit

MEDIUM FORM ALL AUTH + CHECKOUT Form wrappers

DESC: Input fields not wrapped in <form onSubmit>. Users pressing Enter in any input won't trigger form submission.

IMPACT: Poor UX; violates user expectations; accessibility issue for keyboard users.

FIX:

```
Wrap each form step in <form onSubmit={handleSubmit}> with e.preventDefault().
```

LP-2 Auto-Scroll Resumes After User Manual Scroll

MEDIUM UX LANDINGPAGE Auto-scroll interval

DESC: 5-second auto-scroll timer restarts after manual scroll. After 5s, auto-scroll fights with user's position.

IMPACT: Carousel auto-advances while user is browsing, pulling view away.

FIX:

```
Add userInteracted ref that prevents auto-scroll; reset after 15s inactivity.
```

LP-3 Mobile Home Nav Button Doesnt Scroll to Hero

MEDIUM NAVIGATION LANDINGPAGE Mobile Home button

DESC: Mobile Home calls navigateTo(landing) but not scrollToSection(hero). If already on landing page, clicking Home does nothing.

IMPACT: Mobile users cant scroll back to top/hero section via Home nav item.

FIX:

```
Add scrollToSection(hero) to mobile Home action.
```

NAV-1 No Sign Out Option in Mobile Navigation Menu

MEDIUM NAVIGATION APPNAVBAR Mobile Sheet content

DESC: Mobile hamburger menu shows nav links, Cart, Login/Profile but has no Sign Out button.

IMPACT: Mobile users must navigate to Profile page to log out.

FIX:

```
Add Sign Out button in mobile menu when user is logged in.
```

PDP-10 progressFetchKey Never Incremented (Dead Refresh)

MEDIUM STATE PRODUCTDETAILPAGE progressFetchKey

DESC: progressFetchKey used in dep array of progress fetch effect but setProgressFetchKey never called. Progress cannot be manually refreshed.

IMPACT: After completing learning module, progress display may be stale until full reload.

FIX:

```
Increment progressFetchKey on window focus or navigation back.
```

PDP-14 Flash of Incorrect Learning Button While Progress Loads

MEDIUM UX PRODUCTDETAILPAGE Learning status rendering

DESC: productProgress is null until fetch completes. getLearningStatus(null) returns NOT_STARTED, showing Start Learning button briefly for returning users.

IMPACT: Returning users see Start Learning for ~200-500ms before it corrects to Continue Learning.

FIX:

```
Show loading skeleton while progress is being fetched.
```

PDP-8 Native Share Fallback on User Cancel

MEDIUM UX PRODUCTDETAILPAGE handleNativeShare

DESC: When navigator.share() is cancelled (AbortError), catch block falls back to clipboard copy. User intentionally dismissed share but gets clipboard write.

IMPACT: Unwanted clipboard modification and confusing toast after user cancelled sharing.

FIX:

```
Check for AbortError and only fall back for other errors.
```

PDP-9 copied State Declared But Never Rendered

MEDIUM STATE PRODUCTDETAILPAGE copied state

DESC: copied state toggled but no rendered element reads it. Feedback relies entirely on toast.success().

IMPACT: Unnecessary re-renders from dead state.

FIX:

```
Remove copied state or use it for visual indicator.
```

SEC-10 No Rate Limiting on Auth Endpoints

MEDIUM SECURITY AUTH API login/register routes

DESC: No rate limiting on login or registration. Attacker can brute-force passwords at thousands of attempts per second.

IMPACT: Brute-force password attacks, credential stuffing, account enumeration.

FIX:

```
Add rate limiting middleware. Limit to ~5 login attempts per minute per IP.
```

SF-1**Social Media Buttons Are Non-Functional****MEDIUM** **NAVIGATION** **SITEFOOTER** Social media buttons

DESC: Instagram, Twitter, LinkedIn, YouTube buttons have aria-label but no onClick or href. Clicking does nothing.

IMPACT: Users attempting to follow brand on social media get no response - dead buttons.

FIX:

```
Add real social media URLs to onClick handlers or convert to <a> tags.
```

SF-2**window.open() Without noopener,noreferrer****MEDIUM** **SECURITY** **SITEFOOTER / POLICYPAGE** window.open() calls

DESC: All window.open(url, _blank) calls missing noopener and noreferrer. Allows tab-napping/phishing.

IMPACT: Security vulnerability - opened pages can manipulate opener window.

FIX:

STORE-1**Cart Item Key Collision (productId-only matching)****MEDIUM** **LOGIC** **APP STORE** addToCart()

DESC: cart.find(i => i.productId === item.productId) matches only on productId. Same product as one-time and subscription incorrectly merged.

IMPACT: Users cannot buy same product in different purchase modes simultaneously.

FIX:

```
Use composite key: productId:purchaseType:packType.
```

STORE-3**resetForLogout Doesnt Reset All State****MEDIUM** **STATE** **APP STORE** resetForLogout()

DESC: Doesnt reset currentIndex, currentQuizIndex, or adminTab. After logout, these retain stale values.

IMPACT: Stale UI state from previous session leaks into new session.

FIX:

```
Add currentIndex: 0, currentQuizIndex: 0, adminTab: dashboard to reset.
```

• Low Severity

12 issues

A11Y-1 Privacy Policy / Terms of Service Are Non-Interactive Plain Text

LOW A11Y AUTHPAGES Legal Links text

DESC: Rendered as <p>Privacy Policy · Terms of Service</p> with no click handlers or <a> tags.

IMPACT: Users cannot view privacy policy or terms; legally questionable for registration flow.

FIX:

Make them clickable links navigating to policy pages.

ADM-39 Missing ARIA Labels on Sidebar Nav

LOW A11Y ADMINPANEL Sidebar nav

DESC: When sidebar collapsed, only title attribute set. No aria-label for screen readers.

IMPACT: Screen reader users cannot identify nav items when sidebar collapsed.

FIX:

Add aria-label={item.label} to all nav buttons.

ADM-43 Insufficient Product Validation

LOW FORM ADMINPANEL handleSaveProduct

DESC: Only validates name and price. No validation for: price > 0, mrp >= price, stock >= 0, slug format, gst_rate range.

IMPACT: Invalid products can be created (negative price, MRP < selling price, etc.).

FIX:

Add comprehensive validation before API call.

API-7 Admin Users Search Is Case-Sensitive

LOW API ADMIN USERS API Search filter

DESC: Prisma contains filter is case-sensitive by default with SQLite. Searching "john" wont find "John".

IMPACT: Admin search less useful - must match exact case.

FIX:

AUTH-8 Password Strength Minimum Too Weak (6 chars)

LOW LOGIC AUTHREGISTER getPasswordStrength

DESC: Password validation requires only 6 characters with no complexity. "aaaaaa" is accepted.

IMPACT: Users create easily crackable passwords.

FIX:

Enforce minimum 8 chars and at least 1 number or special character.

CHECKOUT-5 Online Payment Methods Show "coming soon" But Still Create Orders

LOW LOGIC CHECKOUTVIEW Payment methods

DESC: UPI, Card, Net Banking show "coming soon" but Place Order button still enabled. Orders created with PENDING payment indefinitely.

IMPACT: Orders with online payment methods have PENDING payment status forever.

FIX:

Disable Place Order for non-COD methods until Razorpay is integrated.

LP-7 CTA Section Image Has Empty alt Text

LOW A11Y LANDINGPAGE CTA section image

DESC: Image with alt="" for what appears to be a meaningful product shot.

IMPACT: Screen readers skip the image entirely, missing visual context.

FIX:

Change to alt="NOTJUST WATER pre-meal wellness shot product image".

PDP-15

No aria-expanded on View More/Less Button

LOW A11Y PRODUCTDETAILPAGE View More/Less button

DESC: Button toggles content expansion but lacks aria-expanded and aria-controls attributes.

IMPACT: Screen readers cannot communicate the expand/collapse state.

FIX:

```
Add aria-expanded={descExpanded} and aria-controls="product-description".
```

PDP-18

Array Index as key on Highlights and Ingredients

LOW RENDER PRODUCTDETAILPAGE Highlights/Ingredients lists

DESC: Using array index as React key is fragile. May cause animation glitches if data reorders.

IMPACT: Low risk since data is stable, but anti-pattern.

FIX:

```
Use item text as key: key={h} or key={`highlight-${h}`}.
```

PDP-21

Quantity State with No UI Controls

LOW UX PRODUCTDETAILPAGE quantity state

DESC: quantity initialized to 1 and passed to addToCart but no UI exists to change it (no +/- buttons). Imported Minus/Plus icons suggest planned but unimplemented feature.

IMPACT: Users who want multiple units must add to cart repeatedly.

FIX:

```
Implement quantity controls using already-imported Minus/Plus icons.
```

SF-3

Footer External Links Use <button> + window.open Instead of <a>

LOW A11Y SITEFOOTER External links

DESC: WhatsApp, email, phone links are <button> with onClick → window.open(). Wrong semantic role.

IMPACT: Screen readers announce as buttons not links; cant right-click to copy URL.

FIX:

```
Replace with <a href="https://wa.me/..." target="_blank" rel="noopener noreferrer">.
```

STORE-5

User Profile Data Persisted in Plaintext localStorage

LOW SECURITY APP STORE Zustand persist

DESC: User object (email, phone, name) persisted to localStorage in plaintext via Zustand persist middleware.

IMPACT: PII exposure if browser/device shared or via XSS.

FIX:

```
Use encrypted storage (e.g., CryptoJS) or a secure backend for user profile data.
```